

PLAYBOOK

INCIDENT RESPONSE

Iron4Software

Version	1.0
Date de création	22 juin 2026
Dernière mise à jour	22 juin 2026
Classification	CONFIDENTIEL - Usage interne uniquement
Référence incident	INC-2026-001
Propriétaire	Analyste SOC Iron4Software

Rappel : Ce playbook a été rédigé sur la base de l'incident INC-2026-001 (compromission Iron4Software, mars 2026) et constitue la procédure de référence pour tout incident de type intrusion réseau, brute-force ou ransomware affectant l'infrastructure Iron4Software.

1. Objet et Périmètre

Ce playbook définit la procédure de réponse à incident (IR) applicable à l'infrastructure Iron4Software. Il est destiné à l'analyste SOC en charge de la supervision et couvre l'ensemble du cycle de vie d'un incident de sécurité : détection, triage, contention, éradication, récupération et clôture.

1.1 Périmètre d'application

Composant	Adresse IP	Rôle
pfSense	192.168.50.7 (WAN) / 192.168.3.253 (LAN)	Pare-feu périmétrique
Windows Server 2019	192.168.3.10	Contrôleur de Domaine Active Directory
Ubuntu Web	192.168.3.11	Serveur web Apache
Ubuntu Splunk	192.168.3.20	SIEM - collecte et corrélation des logs
Windows 10 Client	192.168.3.2	Poste d'administration

1.2 Types d'incidents couverts

Type d'incident	Exemples de signaux déclencheurs
Intrusion périmétrique	Scan de ports, tentatives de connexion depuis le WAN, webshell actif
Brute-force / Credential Access	Volumétrie anormale d'Event ID 4625 sur une courte période
Ransomware / Impact données	Event ID 4663 en masse sur répertoires sensibles, extensions suspectes
Exfiltration de données	Transferts RDP anormaux, connexions sortantes non autorisées

2. Critères de Déclenchement

Ce playbook est déclenché dès qu'une ou plusieurs des alertes suivantes apparaissent dans Splunk avec une sévérité Critical. Une seule alerte suffit à ouvrir un ticket d'incident.

Alerte Splunk	Requête SPL associée	Seuil	Sévérité
Alert Brute Force Windows detected	index=main sourcetype="WinEventLog:Security" EventCode=4625	> 5 résultats / 15 min	Critical
Alert Ransomware Detected !	index=main sourcetype="WinEventLog:Security" EventCode=4663 (DELETE OR écriture OR ajout)	> 2 résultats / 15 min	Critical

Intrusion detected on the WAN	index=main sourcetype="syslog" "block"	> 0 résultat / 5 min	Critical
-------------------------------	--	----------------------	----------

Règle d'or : En cas de doute sur la légitimité d'une alerte, traiter comme un incident réel. Il est toujours préférable d'investiguer un faux positif que d'ignorer une compromission réelle.

3. Rôles et Responsabilités

Rôle	Responsabilités	Contact
Analyste SOC (Tier 1)	Détection, triage initial, ouverture du ticket d'incident, exécution du playbook	SOC Iron4Software
Responsable Sécurité (RSSI)	Validation des décisions de contention majeures, escalade vers la direction	Direction Iron4Software
Administrateur Système	Support technique pour les actions sur les VMs (pfSense, AD, Ubuntu)	IT Iron4Software
DPO / Juridique	Notification CNIL en cas de violation de données personnelles (RGPD Art. 33)	Direction Iron4Software

4. Phases de Réponse à Incident

PHASE 1 TRIAGE ET QUALIFICATION

Le triage est la première action à mener dès réception d'une alerte. L'objectif est de confirmer ou d'infirmier l'incident en moins de 15 minutes et d'ouvrir un ticket formalisé.

4.1.A Vérification initiale dans Splunk

- ☐ Accéder au dashboard Iron4Software – SOC Supervision et identifier les panels en alerte
- ☐ Consulter Activity > Triggered Alerts pour lister toutes les alertes déclenchées
- ☐ Identifier la première alerte (T0) et noter son horodatage précis
- ☐ Lancer la recherche SPL correspondante pour confirmer la volumétrie réelle des événements
- ☐ Identifier l'IP source, le compte ciblé et le système affecté

4.1.B Ouverture du ticket d'incident

Champ	Description	Exemple (INC-2026-001)
Référence	Format INC-AAAA-NNN (séquentiel)	INC-2026-001
Date de détection	Horodatage T0 de la première alerte	19/04/2026 14h20
Sévérité	Critical / High / Medium / Low	Critical
Systèmes affectés	IP et nom des machines concernées	192.168.3.10 – WIN-HKVM4FR00PS
Source attaquante	IP source identifiée dans les logs	192.168.50.5 – Kali Linux
Nature	Type d'incident (ransomware, brute-force...)	Ransomware + exfiltration données santé

4.1.C Matrice de sévérité

Sévérité	Critères	Délai de réponse
Critical	Compromission confirmée, données exfiltrées, ransomware actif	Immédiat – < 15 min
High	Brute-force en cours, accès non autorisé détecté	< 30 min
Medium	Tentatives bloquées, anomalie comportementale	< 2h
Low	Faux positif probable, bruit réseau	< 24h

PHASE 2 CONTENTION

La contention vise à stopper immédiatement la propagation de l'attaque sans détruire les preuves forensiques. Toutes les actions de contention doivent être horodatées et documentées dans le ticket d'incident.

IMPORTANT : Ne jamais supprimer de fichiers, de logs ou de règles firewall avant la phase d'éradication. Les preuves doivent être préservées pour l'analyse forensique post-incident.

4.2.A Blocage de l'IP attaquante (pfSense WAN)

- ☐ Se connecter à l'interface pfSense via <https://192.168.3.1> depuis le poste admin (192.168.3.2)
- ☐ Naviguer vers Firewall > Rules > WAN
- ☐ Créer une règle Block en première position : Action=Block, Protocol=Any, Source=IP_attaquante, Destination=Any
- ☐ Nommer la règle : IR [INC-XXXX-NNN] – Blocage IP attaquante
- ☐ Sauvegarder et appliquer les changements – vérifier le statut X rouge sur la règle
- ☐ Documenter l'heure d'application dans le ticket d'incident

4.2.B Isolation du système compromis (pfSense LAN)

- ☐ Naviguer vers Firewall > Rules > LAN
- ☐ Créer une règle Block en première position : Action=Block, Protocol=Any, Source=Any, Destination=IP_système_compromis
- ☐ Nommer la règle : IR [INC-XXXX-NNN] – Isolation [NomMachine] compromis
- ☐ Positionner la règle AU-DESSUS des règles existantes (ordre critique dans pfSense)
- ☐ Sauvegarder et appliquer – vérifier que le système est bien injoignable depuis le LAN
- ☐ Ne pas supprimer la règle après usage : la désactiver via Toggle pour traçabilité

4.2.C Désactivation du compte compromis (Active Directory)

- ☐ Se connecter au Windows Server 2019 (console locale ou session RDP depuis poste admin)
- ☐ Ouvrir Utilisateurs et ordinateurs Active Directory (dsa.msc)
- ☐ Localiser le compte compromis, clic droit > Désactiver le compte
- ☐ Vérifier l'icône flèche vers le bas confirmant la désactivation
- ☐ Ne pas réinitialiser le mot de passe avant la phase d'éradication
- ☐ Documenter le compte désactivé et l'horodatage dans le ticket d'incident

L'éradication consiste à supprimer tous les artefacts de l'attaquant et à corriger les vulnérabilités exploitées. Cette phase ne commence qu'après validation complète de la contention.

4.3.A Nettoyage du serveur web Ubuntu

- ☐ Se connecter en SSH sur l'Ubuntu Web (192.168.3.11)
- ☐ Vérifier la présence de webshells : `ls -la /var/www/html/`
- ☐ Supprimer tout fichier PHP suspect : `sudo rm /var/www/html/[fichier_suspect].php`
- ☐ Vérifier l'absence de résidu : `ls -la /var/www/html/` (seul index.html doit rester)
- ☐ Contrôler les logs Apache pour identifier d'autres fichiers potentiellement accédés :
`sudo grep -i '.php' /var/log/apache2/access.log | grep -v index`
- ☐ Vérifier les crontabs utilisateur : `crontab -l && sudo crontab -l`

4.3.B Nettoyage du Windows Server 2019

- ☐ Ouvrir le Planificateur de tâches (taskschd.msc)
- ☐ Inspecter la racine de la Bibliothèque du Planificateur – vérifier l'absence de tâches suspectes
- ☐ Vérifier les services Windows anormaux : services.msc – trier par Date de démarrage
- ☐ Contrôler les clés de registre de démarrage automatique :
 - ☐ HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
 - ☐ HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
- ☐ Inspecter le dossier PRIVATE et identifier tous les artefacts ransomware présents
- ☐ Ne pas supprimer les artefacts avant validation par l'analyste forensique post-incident

4.3.C Réinitialisation des credentials compromis

- ☐ Réinitialiser le mot de passe du compte compromis via CMD en administrateur :
`net user [NomCompte] *`
- ☐ Choisir un mot de passe fort : minimum 14 caractères, majuscules, chiffres, caractères spéciaux
- ☐ Réactiver le compte dans Active Directory (dsa.msc) : clic droit > Activer le compte
- ☐ Vérifier que la GPO de verrouillage est active : seuil à 5 tentatives maximum
- ☐ Documenter le nouveau mot de passe dans un gestionnaire de mots de passe sécurisé

Validation de l'éradication : Avant de passer à la récupération, s'assurer que tous les vecteurs d'attaque identifiés ont été traités. Relancer un scan Splunk sur les IoC connus pour confirmer l'absence de nouvelle activité suspecte.

La récupération vise à remettre les systèmes en production dans un état sain et contrôlé. Elle s'effectue de manière progressive, système par système, avec validation à chaque étape.

4.4.A Levée de l'isolation réseau

- ☐ Retourner dans pfSense > Firewall > Rules > LAN
- ☐ Désactiver la règle d'isolation via le bouton Toggle (ne pas supprimer – conserver pour traçabilité)
- ☐ Vérifier que les règles RDP légitimes sont toujours en place (poste admin uniquement)
- ☐ Tester la connectivité du système depuis le poste admin (192.168.3.2)
- ☐ Vérifier dans Splunk que les logs reprennent normalement depuis le système remis en ligne

4.4.B Restauration des données

- ☐ Vérifier la disponibilité de sauvegardes dans C:\BACKUPS_SECURE
- ☐ Si sauvegarde disponible : restaurer les fichiers depuis la sauvegarde la plus récente avant l'incident
- ☐ Si aucune sauvegarde disponible : procéder à une restauration manuelle depuis la dernière version connue
- ☐ Vérifier l'intégrité des fichiers restaurés (noms, extensions, taille)
- ☐ Supprimer les artefacts ransomware résiduels (notes de rançon, fichiers renommés)
- ☐ Documenter la méthode de restauration et les fichiers concernés dans le ticket d'incident

Point critique – Sauvegardes : Suite à l'incident INC-2026-001, il a été constaté que C:\BACKUPS_SECURE était vide faute de politique de sauvegarde automatisée. La mise en place d'une sauvegarde planifiée est une priorité post-incident (voir Section 8).

4.4.C Validation de la remise en production

Système	Test de validation	Résultat attendu
pfSense	Scan Nmap depuis WAN sur ports 80, 443, 22, 3389	Tous les ports filtered
Ubuntu Web	Accès HTTP depuis WAN – vérifier absence shell.php	Page par défaut Apache uniquement
Windows Server	Tentative brute-force SMB (5 essais)	Compte verrouillé après 5 tentatives
Splunk	Vérifier remontée des logs depuis tous les forwarders	Événements récents visibles dans index=main
Active Directory	Connexion avec les nouveaux credentials Administrateur	Authentification réussie

5. Clôture et Documentation

La clôture d'un incident n'est prononcée qu'après validation de toutes les étapes de récupération et production des livrables obligatoires.

5.1 Checklist de clôture

- ☐ Tous les vecteurs d'attaque identifiés ont été traités et documentés
- ☐ Tous les systèmes affectés ont été nettoyés et remis en production
- ☐ Les credentials compromis ont été réinitialisés
- ☐ Les règles de contention pfSense ont été désactivées (et conservées pour traçabilité)
- ☐ Les données affectées ont été restaurées et leur intégrité vérifiée
- ☐ La Fiche d'Incident (INC-XXXX-NNN) est complétée avec tous les horodatages
- ☐ La notification CNIL est effectuée si des données personnelles ont été exfiltrées (RGPD Art. 33 – délai 72h)
- ☐ Un rapport forensique est initié pour reconstituer la timeline complète de l'attaque et identifier tous les IoC
- ☐ Un plan de communication de crise est préparé pour informer la direction, les clients et partenaires concernés
- ☐ Les recommandations post-incident sont documentées et transmises à la direction

6. Leçons Apprises (INC-2026-001)

Cette section synthétise les enseignements tirés de l'incident INC-2026-001 pour améliorer la posture de sécurité Iron4Software et affiner ce playbook.

Constat	Impact	Mesure corrective
Webshell accessible depuis le WAN	Point d'entrée initial de l'attaquant	Supprimer les fichiers de test du répertoire web – activer un WAF
Règle WAN Allow All sur pfSense	Pivot direct depuis l'extérieur vers le LAN sans friction	Politique de moindre privilège sur toutes les règles pfSense
Mot de passe trivial (Admin123)	Brute-force réussi en moins de 45 minutes	Politique de mots de passe complexes + rotation régulière
Absence de seuil de verrouillage AD	Brute-force illimité possible	GPO : seuil de verrouillage à 5 tentatives – déjà appliqué lors du durcissement de l'infrastructure
C:\BACKUPS_SECURE vide	Restauration manuelle de dernier recours	Mettre en place une sauvegarde automatisée et testée mensuellement
Canaux RDP non restreints	Exfiltration via presse-papiers RDP	GPO : désactiver le presse-papiers et la redirection de lecteurs RDP

Détection tardive (6 semaines après compromission)	Fenêtre d'exposition longue	Renforcer l'ingénierie de détection - alertes en temps réel sur webshells
--	-----------------------------	---

7. Annexes et Références

7.1 Contacts d'urgence

Entité	Rôle	Contact / URL
CNIL	Notification violation de données personnelles	https://www.cnil.fr/fr/notifier-une-violation-de-donnees-personnelles
ANSSI	Signalement incident cybersécurité majeur	https://www.cert.ssi.gouv.fr
Cybermalveillance.gouv.fr	Assistance aux victimes de cyberattaques	https://www.cybermalveillance.gouv.fr

7.2 Références techniques

Ressource	Description	URL
MITRE ATT&CK;	Framework de classification des techniques d'attaque	https://attack.mitre.org
NIST SP 800-61	Guide de réponse à incident NIST	https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final
Splunk Security	Documentation alertes et dashboards Splunk	https://docs.splunk.com/Documentation/Splunk
pfSense Docs	Documentation règles firewall pfSense	https://docs.netgate.com/pfsense/en/latest

7.3 Event IDs Windows clés

Event ID	Description	Contexte SOC
4625	Échec d'ouverture de session	Brute-force - surveiller Logon_Type=3 (réseau)
4624	Succès d'ouverture de session	Compromission - filtrer Logon_Type=3 + IP externe
4663	Accès à un objet (fichier)	Ransomware - surveiller DELETE + écriture sur dossiers sensibles
4670	Modification des permissions d'un objet	Tentative de contournement des ACL BACKUPS_SECURE
4720	Création d'un compte utilisateur	Persistence - création de backdoor compte
4732	Ajout d'un membre à un groupe	Élévation de privilèges

